KILLERBEE · PHASE 4

Sauvegardes immuables & journaux Wazuh

Amélioration de la sécurité du SI

Cloud hybride | S3NS PREMI3NS | Bucket Lock



SAUVEGARDES IMMUABLES

Constat et problématique

L'infrastructure repose sur Proxmox, qui héberge :

- **Contrôleur de domaine AD**
- **Serveur Wazuh**
- **Serveurs applicatifs**
- **VM de sauvegarde**

Aucune tâche planifiée visible

Aucune sauvegarde planifiée n'apparaît dans l'interface Proxmox. Cela ne signifie pas qu'aucune sauvegarde n'existe : leur organisation et leur protection restent à vérifier.

Compromissions démontrées

Les attaques de la Red Team ont mis en évidence plusieurs compromissions importantes, notamment sur Active Directory et sur le serveur Drupal.

Risque principal

Une sauvegarde conservée uniquement en local pourrait être supprimée par un attaquant ou devenir indisponible en cas de panne majeure.

SAUVEGARDES IMMUABLES

Solution : une architecture hybride

INFRASTRUCTURE LOCALE

Proxmox

- **Active Directory**
- **Wazuh**
- **Serveurs applicatifs**
- **VM de sauvegarde**

Machines virtuelles et services conservés en local

COPIE

sauvegardes critiques

CLOUD DE CONFIANCE

S3NS PREMI3NS

Bucket Lock · rétention verrouillée

Espace dédié avec durée de conservation définie : les copies protégées ne peuvent pas être supprimées prématurément, même si certains accès sont compromis.

Les sauvegardes sont produites localement, puis copiées vers S3NS.

SAUVEGARDES IMMUABLES

Deux solutions étudiées

OPTION 1

AWS S3

- Stockage cloud avec la fonctionnalité S3 Object Lock
- Protège les versions sauvegardées contre la suppression pendant une période définie

CHOIX RETENU

OPTION 2

S3NS PREMI3NS

- Cloud de confiance français
- Offre qualifiée SecNumCloud 3.2 par l'ANSSI
- Bucket Lock : verrouillage d'une politique de conservation des données

Pourquoi S3NS ? Ses garanties de confiance et de souveraineté sont particulièrement adaptées à une infrastructure contenant des informations sensibles.

SAUVEGARDES IMMUABLES

Bénéfices et points de vigilance

Résilience

Récupérationaprès compromission ou panne locale.

Immuabilité

Copiesprotégéescontre modification ou suppression.

Souveraineté

Utilisation d'uneoffre cloud de confiance française.

Continuité

Moinsdedépendance aux équipements locaux pour restaurer.

POINTS DE VIGILANCE

- Vol ou mauvaise gestion des identifiants cloud
- Mauvaise configuration des autorisations, exposition de données sensibles
- Coûts de stockage, de transfert et de restauration
- Vérification régulière de l'intégrité et de la capacité de restauration

Proposition d'amélioration : aucun déploiement cloud n'a été réalisé.

JOURNAUX DE SÉCURITÉ WAZUH

Constats des Phases 2 et 3

Wazuhcentraliseetanalyselesévénementsdesécuritédesmachines surveillées.

Phase 2 · constat C31

La Red Team a compromis le contrôleur de domaine et récupéré la clé d'authentification de son agent Wazuh : la fiabilité de la supervision peut être menacée.

Phase 3 · traces retrouvées

Certaines traces figuraient dans Wazuh, notamment une connexion RDP avec le compte pentest-svc.

Phase 3 · angle mort

Les journaux ne permettaient pas de retracer précisément certaines requêtes HTTP liées aux attaques contre l'application KillerBee.

DEUX BESOINS COMPLÉMENTAIRES

Améliorer la collecte

Enregistrerdavantaged'événements applicatifs utiles.

Améliorer la conservation

Neplusdépendreuniquementduserveur Wazuh local.

JOURNAUX DE SÉCURITÉ WAZUH

Fonctionnement envisagé

1

Collecte

Les agents Wazuh collectent les événements des machines surveillées.

2

Applicatif

Les journaux applicatifs sont intégrés à la collecte si nécessaire.

3

Export

Les journaux sont exportés vers un espace S3NS distinct de celui des sauvegardes.

4

Verrouillage

Bucket Lock protège les archives contre une suppression prématurée.

5

Droits limités

Le compte d'envoi peut déposer des fichiers, jamais supprimer les archives.

Sécurité du transfert Transferts chiffrés · accès au stockage réservés aux comptes autorisés

JOURNAUX DE SÉCURITÉ WAZUH

Bénéfices et limites

Conservation des preuves

Les journaux déjà transférés restent disponibles même si Wazuh local est compromis.

Résilience

Copie indépendante de l'infrastructure Proxmox.

Protection contre la suppression

Période de conservation immuable pour les archives.

Meilleure investigation

Des traces historiques protégées facilitent l'analyse d'incident.

LIMITES ET VIGILANCE

- Impossible de récupérer des événements jamais enregistrés : améliorer la journalisation de l'application reste indispensable
- Ne remplace ni la surveillance des alertes Wazuh, ni la correction de C31
- Confidentialité des journaux, identifiants cloud, flux sortants, coûts de conservation

CONCLUSION

Mieux protéger, sans tout migrer

Les sauvegardes critiques

Faciliter larestauration aprèsuneattaque ou une panne, grâce à des copies immuables sur S3NS.

Les journaux Wazuh

Préserverlestraces desécuriténécessaires aux investigations, indépendamment du serveur local.

ChoixdeS3NS : souveraineté,qualificationSecNumCloud3.2,conservationimmuableavecBucketLock.

Notre objectif n'est pas de migrer KillerBee vers le cloud, mais de mieux protéger les sauvegardes et les preuves de sécurité en cas d'incident.